
REGOLAMENTO DORA, LOTL E THREAT SHIFTING: IMPLICAZIONI PER LA CYBER SECURITY

Fabrizio Baiardi

Professore Ordinario di Informatica presso l'Università di Pisa
e co-founder di Haruspex

WHITEPAPER 06/2024



INDICE

06 **Due premesse**

06 **Intrusioni: lo scenario attuale**

Le intrusioni accelerano

Living Off the Land (LOTL)

Il ransomware innova

Tempo per la rilevazione di una intrusione

09 **TLPT e TIBER: i tempi**

11 TPLT e TIBER: il team

12 Le rilevazione e le notifiche

12 Conclusioni

CYBER CRIME CONFERENCE

17-18 APRILE 2024

AUDITORIUM DELLA TECNICA, ROMA

Iscriviti alla newsletter di ICT Security Magazine
per conoscere l'agenda e partecipare alla
12^a Edizione della Cyber Crime Conference

ABOUT THE AUTHOR

Fabrizio Baiardi

Professore Ordinario di Informatica presso l'Università di Pisa e co-founder di Haruspex

Laureato in scienze dell'informazione è attualmente professore ordinario di informatica al Dipartimento di informatica dell'Università di Pisa. I suoi interessi di ricerca sono centrati su approcci formali per la valutazione e gestione del rischio cyber. Ha guidato e coordinato gruppi di lavoro che hanno valutato e gestito il rischio di infrastrutture critiche ICT ed OT. Attualmente si interessa della produzione di dati sintetici per la valutazione quantitativa ed accurata del cyber risk mediante modelli digitali dei sistemi informatici e delle loro minacce. E' uno dei fondatori ed advisor scientifico di Haruspex, una start up innovativa tutta italiana che offre piattaforme informatiche per la gestione proattiva del rischio cyber. Ha un'amore non corrisposto per la bicicletta e odia con tutto il suo cuore i capture the flag.

Due premesse

Due premesse sono necessarie. La prima è che sono stato membro di un gruppo di lavoro di AIEA, associazione italiana degli EDP auditor, su DORA. Ovviamente tutto quanto discusso in questo articolo sono le mie opinioni personali e non quelle del gruppo di lavoro o della associazione. La seconda premessa è che non ho mai avrò una mentalità legale in grado di analizzare le leggi ed i regolamenti e le loro nascoste relazioni, rinvii o contraddizioni. Quello che mi interessa è capire il contesto e l'analisi dello scenario che ha portato a definire una legge. Ciò mi rende costituzionalmente incapace di risolvere il problema di come sia possibile rispettare formalmente una norma mentre in realtà la si viola. So bene che il problema è molto importante nel mondo reale ed anche in quello accademico, ma purtroppo nel seguito non troverete una soluzione.

Detto questo, i due principali punti del regolamento DORA che voglio evidenziare sono la frequenza dei Threat Lead Penetration Test, TLPT, in pratica un penetration test dove si emula una specifica minaccia, e quello del team che questo TLPT deve eseguire. Accennerò ad altri problemi sulla notifica di incidenti. Nei capitoli successivi discuterò questi punti dopo aver descritto brevemente lo scenario attuale delle intrusioni nei sistemi informatici che è la causa principale delle mie obiezioni.

Intrusioni: lo scenario attuale

Riassumo brevemente lo scenario attuale delle intrusioni informatiche e quello dell'ecosistema criminale che le genera per individuare alcune caratteristiche generali delle attuali minacce, cioè degli attuali attaccanti.

Le intrusioni accelerano

Quasi tutte le analisi concordano nell'evidenziare che le intrusioni stanno diventando più veloci e più stealth, ovvero più difficili da individuare. Queste tendenze sono favorite da un lato da un ecosistema criminale dove i potenziali attaccanti trovano in vendita, grazie agli initial access broker, i fornitori di accessi iniziali alla infrastruttura informatica di una organizzazione. Utilizzando questo accesso un attaccante può iniziare la sua

intrusione dall'interno del sistema target riducendo così sensibilmente il tempo necessario. Il gran numero di access broker è dimostrato dall'aumento degli annunci pubblicitari nei mercati del dark web, dove ogni broker promuove le proprie offerte indicando, ad esempio, il fatturato delle aziende le cui infrastrutture sono oggetto di vendita per l'accesso.

Gli stessi mercati offrono malware, ad esempio per intrusioni ransomware in cambio di una percentuale dei ricavi. La forte competizione tra fornitori, come nel caso degli initial access broker porterà, come in tutti i mercati, ad una riduzione dei prezzi che aumenterà la redditività delle intrusioni, basti pensare che esistono accessi che costano meno di 10 dollari.

L'offerta dei mercati nel dark web permette anche a criminali non particolarmente esperti di creare intrusioni acquistando gli strumenti necessari invece di svilupparli. Ciò aumenta sia il numero di attaccanti che di intrusioni e quindi anche la probabilità di essere attaccati. L'aumento degli attaccanti è dovuto anche alla diffusione di piattaforme offensive in grado di eseguire automaticamente alcuni o tutti i passi di una intrusione. La condivisione di malware e piattaforme d'attacco nei mercati del dark web consente a un gruppo criminale di adattare rapidamente le proprie strategie e tecniche d'attacco quando i difensori applicano contromisure efficaci.

Living Off the Land (LOTL)

Un'altra ragione dell'accelerazione delle intrusioni è la diffusione di strategie quali la living of the land o, in breve, LOTL. Questa strategia prevede che l'attaccante utilizzi al massimo strumenti già esistenti nel sistema da attaccare, la terra che lo alimenta, risparmiando il tempo per sviluppare o personalizzare i propri strumenti. Quindi l'attaccante non userà una propria shell ma quella di amministrazione, né i propri strumenti per eliminare le difese. Invece, manipolerà quelli di end point protection per far sì che considerino malware gli strumenti di difesa e li eliminino. In intrusioni LOTL, gli attaccanti creano inizialmente un proprio accesso permanente a risorse periferiche di un sistema, ad esempio il router di frontiera che connette il sistema ad internet oppure le VPN appliances, i firewalls o i routers, fase detta anche living on the edge. Successivamente, usano l'accesso permanente per capire quali sono gli strumenti utilizzati nel sistema target e come usarli a loro favore. La strategia LOTL è molto popolare tra APT ed attaccanti state sponsored, quelli più interessati agli impatti di tipo sistemico che la direttiva DORA vorrebbe prevenire. LOTL è stata inizialmente utilizzata da alcuni attaccanti state sponsored da paesi dell'estremo oriente ma, per la sua efficacia, si è diffusa rapida-

mente ad altri attaccanti state sponsored ma di paesi dell'europa orientale. Ad esempio, un recente rapporto Mandiant indica che LOTL è stata adottata anche da Sandworm, il gruppo che fa riferimento al GRU, il servizio militare russo. Sandworm, indicato anche come APT 44, avrebbe utilizzato questa strategia in intrusioni contro infrastrutture critiche statunitensi per lo stoccaggio e la distribuzione d'acqua. Ma quello che interessa è evidenziare:

- l'accelerazione delle intrusioni permessa da LOTL,
- la rapida diffusione di LOTL tra attaccanti provenienti da paesi diversi.

Queste osservazioni e quelle sull'ecosistema criminale confermano l'estrema rapidità degli attaccanti nel modificare le proprie strategie se ciò permette di accelerare le intrusioni e di aumentare la loro probabilità di successo. Questa disponibilità alla innovazione degli attaccanti produce quello che viene indicato come threat shifting ovvero la capacità dell'attaccante di mutare il proprio comportamento, le proprie risorse, i propri tempi d'azione per aumentare la sua probabilità di successo e reagire alle contromisure scelte dai difensori. Il threat shifting è ben noto e già descritto nella Guide for Conducting Risk Assessments preparata dal US National Institute of Standards and Technologies nel 2012.

Il ransomware innova

Anche le evoluzioni del ransomware, dove la vittima paga per riottenere la disponibilità dei propri dati, confermano la disponibilità degli attaccanti ad innovare. Infatti, in pochi anni siamo passati dalla intrusione ransomware semplice, in cui l'attaccante cifra i dati e chiede un riscatto per la chiave per decifrare, alla doppia ed alla tripla estorsione dove l'attaccante esfiltra anche i dati prima di cifrarli e poi li usa per aumentare la sua pressione sulla vittima minacciando di pubblicare o di rivendere ad altri i dati esfiltrati con altri impatti economici ed anche legali nel caso di dati personali o sensibili. Le nuove strategie di estorsione richiedono non solo lo sviluppo di nuovo malware per le intrusioni ma anche siti nel dark web per pubblicare i dati o l'utilizzo di competenze per la gestione della trattativa, ora più complessa che in una intrusione semplice. In taluni casi possiamo anche ipotizzare competenze per la scoperta nei dati esfiltrati di informazioni da passare agli stati la cui compiacenza è fondamentale per le gang che eseguono le intrusioni. Anche in questo caso, gli attaccanti non hanno paura di innovare mediante la condivisione di malware o accelerandone la diffusione assumendo chi lavorava per gang la cui infrastruttura sia stata smantellata, come successo di recente con la gang LockBit.

Tempo per la rilevazione di una intrusione

Un ulteriore elemento dello scenario delle intrusioni è il tempo medio necessario per la rilevazione di una intrusione. Questo tempo è estremamente variabile in base al settore dove un'azienda opera ma comunque viene misurato in settimane o giorni nel caso più fortunato. Ad esempio il MITRE, ente ben noto a chi si occupa di sicurezza informatica, ha annunciato nell'Aprile 2024 la scoperta di una intrusione iniziata nel gennaio dello stesso anno. In questa intrusione, che il MITRE attribuisce ad un attaccante sponsorizzato da uno stato, gli attaccanti hanno acquisito informazioni sulla rete Networked Experimentation, Research, and Virtualization Environment (NERVE), una rete non classificata che fa parte della infrastruttura VMware del MITRE. Al 20 aprile, MITRE non è ancora in grado di individuare tutti gli effetti laterali dell'intrusione. Altro fattore di cui tener conto è che, escludendo il caso del ransomware, in più della metà dei casi, una organizzazione scopre l'intrusione per informazioni provenienti dall'esterno.

La diffusione di strategie di tipo LOTL non potrà che aumentare il tempo per la rilevazione sia perchè le intrusioni accelerano sia perchè l'utilizzo da parte degli attaccanti di strumenti già esistenti sul sistema target riduce le opportunità di rilevare una intrusione grazie alla scoperta degli strumenti installati dall'attaccante sul sistema target. In generale, LOTL permette agli attaccanti di ridurre il numero di eventi anomali che l'intrusione genera e che sono registrati nei log del sistema attaccato con tutto quello che ciò comporta.

TLPT e TIBER: i tempi

Il regolamento DORA e gli standard tecnici che lo accompagnano affidano il test delle infrastrutture informatiche delle entità finanziarie con impatti sistemici ad un TLPT cioè ad un penetration test in cui si può decidere il comportamento della minaccia che si intende riprodurre. Nel fare questo, DORA fa riferimento a TIBER, un framework europeo con declinazioni nazionali per l'esecuzione di TPLT. In particolare, DORA specifica che generalmente gli organismi di sorveglianza richiedono ad una organizzazione soggetta a DORA di sottoporsi ad un TPLT con una frequenza almeno triennale che può però essere aumentata. La durata del TPLT non viene fissata esattamente ma TIBER specifica una durata che va da 25 a 35 settimane per le tre fasi di preparazione, esecuzione ed analisi dei risultati. Gli ultimi standard tecnici aumentano la durata di un

TLPT ma riducono la durata dell'esecuzione in favore di una analisi più lunga.

Riassumendo ogni tre anni la resilienza della infrastruttura informatica di una organizzazione viene valutata mediante un test la cui esecuzione, cioè l'intrusione vera e propria, richiede almeno tre mesi. Il tutto senza informare il team che gestisce l'infrastruttura del test in atto.

Nello scenario attuale è difficile capire quale sia il ritorno dello sforzo generato dal test. Qualunque sia il risultato del test, dopo pochi giorni o settimane dalla fine dello stesso, le minacce possono cambiare comportamento e rendere inefficaci le eventuali contromisure. Se le minacce cambieranno dipende unicamente dal ritorno del loro investimento nel cambiamento, visto che hanno dimostrato in passato la loro flessibilità e disposizione al cambiamento. Un'altra causa importante del cambio di comportamento può essere la scoperta di nuove vulnerabilità nei moduli dell'infrastruttura. Ricordo che negli ultimi anni vengono rese pubbliche circa 100 vulnerabilità al giorno, feste comprese. Nuove vulnerabilità abilitano nuovi attacchi e nuove strategie delle minacce per sfruttarli.

Come si valuta la capacità dell'organizzazione di reagire allo threat shift generato dalle varie cause? Non è credibile dire che questa valutazione avverrà nel successivo test triennale perchè gli impatti delle intrusioni in questo intervallo possono essere non solo sistemici, ma devastanti. Poichè lo scenario del rischio generato dalle intrusioni è dinamico altrettanto dinamici devono essere i meccanismi di risposta e quelli di valutazione dell'efficacia della risposta. In particolare, una organizzazione dovrebbe fornire delle evidenze dei processi attivati per rilevare il threat shift ed aggiornare le proprie difese.

Personalmente ritengo che l'unica risposta a questo problema sia l'automazione. L'automazione delle piattaforme per l'emulazione del comportamento delle minacce nelle loro intrusioni permette un assessment continuo e non puntuale di una infrastruttura informatica con una valutazione delle contromisure adottate ed una gestione del rischio continua. L'automazione che non solo è possibile ma è già in atto e può quindi fornire un supporto importante per la soluzione di questo problema con un significativo risparmio di risorse. L'adozione dell'automazione evita di trasformare la scelta dell'intervallo in una lunga negoziazione di un compromesso sull'intervallo tra due assessment o due TLPT. L'ottimizzazione della difesa richiede di minimizzare non di estendere questo intervallo.

Infine, se oltre all'automazione si utilizzano strumenti e piattaforme basate su digital twins e sui dati sintetici che essi generano, gli assessment possono richiedere tempi estremamente brevi ed offrire livelli di confidenza maggiori di quelli permessi da tester o piattaforme offensive che operano sul sistema reale.

TPLT e TIBER: il team

DORA richiede che il TLPT sia condotto da un team di pentester e vi sono discussioni in atto per decidere se questo team debba sempre essere esterno perchè l'uso di penetration tester o red teamer interni potrebbe provocare un conflitto di interessi. Indipendentemente dalla provenienza dei tester, DORA e gli standard tecnici che lo accompagnano specificano anche le competenze richieste ai tester che vengono sostanzialmente definite in termini di "anni di esperienza" in attività di penetration test. In base ai ruoli nel team gli anni richiesti variano da tre a cinque. Altri requisiti sono l'accettazione di uno statuto etico e lettere di referenza di altri clienti.

Un primo immediato problema è come si possono certificare questi requisiti? E chi li deve certificare? L'azienda che fornisce i tester? Anche qui mi pare sorgano alcuni conflitti di interesse. Mi si dirà che il mercato si occuperà di eliminare le aziende che utilizzano tester inadeguati o non preparati. Ma siamo sicuri che il mercato consideri l'uso di penetration tester inadeguati un bug e non una feature? Il dubbio mi pare legittimo visto il vasto ricorso a presunti esperti su blockchain, digitalizzazione, intelligenza artificiale e qualsiasi altro tema legato alle tecnologie ICT.

Altro problema è che buona parte delle attività di un tester sono già e saranno sempre più automatizzate da piattaforme di tipo offensive, come sta avvenendo per le minacce. Questo può permettere di ridurre il numero di anni di esperienza richiesti visto che le piattaforme incapsulano parte delle competenze richieste. Anche la discussione su pentester interni o esterni potrebbe cambiare usando una piattaforma offensive perchè in questo caso non è tanto importante chi utilizza la piattaforma quanto chi decide i bersagli, i percorsi e le strategie che la piattaforma può usare. Evidenze sull'utilizzo della piattaforma e sui risultati prodotti possono essere fondamentali per valutare se gli assessment avvengano con una frequenza adeguata.

Indipendentemente dagli strumenti utilizzati, richiedere ad un pentester non solo l'esperienza ma anche alcuni anni di formazione superiore, preferibilmente nel settore STEM, garantirebbe una migliore capacità di analisi ed una più solida base scientifica alla esperienza e costituirebbe una spinta non trascurabile alla estensione agli attuali percorsi di formazione.

Le rilevazione e le notifiche

DORA richiede la notifica di una intrusione a 4 e a 72 ore dalla sua rilevazione.

Trovo contraddittorio questo obbligo con la durata del TLPT. Come detto, i vari standard tecnici assumono che l'esecuzione del TLPT richieda alcuni mesi in cui il team di difesa non scopre gli attaccanti, o se li scopre non diffonde la notizia. Ammesso questo non è chiaro perché si debba costringere una organizzazione che ha appena rilevato degli attaccanti che, come assume il TLPT, operano magari da settimane nella sua infrastruttura a distogliere risorse per preparare e distribuire una notifica. Anche se nell'ultimo anno la capacità di detection delle organizzazioni è migliorata, la maggior parte delle intrusioni viene scoperta solo grazie ad informazioni esterne. Quindi, con la notevole eccezione delle intrusioni ransomware, molto probabilmente nemmeno dopo 72 ore una organizzazione con una infrastruttura informatica complessa può avere una visione chiara delle risorse che l'attaccante ha raggiunto, del suo livello di persistenza nella infrastruttura, delle informazioni esfiltrate. Probabilmente queste ore sono quelle sufficienti solo per controllare l'aggiornamento dei vari inventari hardware e software. Ricordo che ad esempio una vittima di NoTPetya ha impiegato 72 ore solo per convocare in Inghilterra tutti i responsabili dei siti aziendali colpiti.

Quindi anche dopo 72 la notifica sarà necessariamente povera di informazioni e poco utile. Ovviamente, l'obbligo di notifica è irrinunciabile ma forse sarebbe opportuno alleggerire i vincoli temporali a favore di una informativa più ricca con una prima analisi dell'impatto.

Conclusioni

Le conclusioni che si possono trarre a questo punto sono ovviamente provvisorie. Mi auguro che le varie iniziative di revisione ed analisi attualmente in corso, come quella di AIEA, portino ad un adeguamento del regolamento DORA evitando di dover ricorrere tra qualche anno ad un DORA2.

FORUM ICT SECURITY

23-24 OTTOBRE 2024

AUDITORIUM DELLA TECNICA, ROMA

Iscriviti alla newsletter di ICT Security Magazine
per conoscere l'agenda e partecipare alla
22^a Edizione del Forum ICT Security

The logo for ICT Security Magazine features a stylized icon of three overlapping squares in shades of pink and red to the left of the text. The text 'ICT' is in a large, bold, yellow sans-serif font, while 'Security' is in a larger, bold, yellow script font. Below 'Security', the word 'MAGAZINE' is written in a smaller, bold, pink sans-serif font.

ICT Security MAGAZINE

ISCRIVITI ALLA NEWSLETTER

per ricevere aggiornamenti sulle
prossime iniziative. Seguici sui canali
social: [Linkedin](#), [Facebook](#), [Twitter](#)